

Kişisel ve Güvenli E-Ticaret Sınır

TkMarka — Teknik Sunum

E-Ticaretin Üç Zorlu Yolu

- Haz■r SaaS: markan■n verisi ortak bir havuzda, kontrol sa■lay■c■da.
- Ajans: tek seferlik teslimat, sonras■nda bak■m yükü markada.
- Haz■r tema: h■z var, esneklik yok — özelle■tirme bir noktada duruyor.

Üçünde de ortak sorun: markan■n verisi kendi kontrolünde de■il.

T■kMarka Formülü

- Tek komutla aç■lan, tamamen izole bir e-ticaret altyap■s■.
- Marka hiçbir ■ey kurmuyor — kendi alan ad■nda bir vitrin, personeli için bir yönetim paneli al■yor.
- Abonelik modeli. Kaynak kod teslim edilmiyor; teslim edilen ■ey ayakta tutulan bir hizmet.

Veri İzolasyonunun Ticari Boyutu

“Riskin yönü simetrik değil — biz pahalı olan tarafı değil, ucuz olan tarafı seçtik.”

- Sektörün alışılmışı yolu tek tabloda tenant_id kolonudur. TİkMarka bunu seçmedi.
- Her marka veritabanı düzeyinde kendi ayrı temasında yaşıyor (tenant_).
- tenant_id yolunda unutulmuş TEK bir filtre satır = geri döndürülemez veri silinmesi.
- Tema bazı izolasyonda bu hata sınıfı yapısal olarak imkânsız.

Doğrulama

- 995 otomatik test — fikir değil, ölçülmüş sistem.
- İki geliştirme markasında uçtan uca gerçek HTTP koşullarıyla doğrulanmış akışlar.
- Gerçek bir ödeme sağlayıcısının (iyzico) sandbox ortamında tamamlanmış gerçek işlemler.

"%100 uptime" ve "3 canlı marka" iddiaları kaldırıldı — proje henüz üretime alınmadı (Faz 6 açılmadı).

Ölçüm	Değer
Otomatik test	995
Aktif geliştirme markası	2
Ödeme entegrasyonu	Gerçek sandbox (iyzico)

Teknik Geçiş & Felsefe

- Doğru kurgulanmış mühendislik: her karar, gerekçesiyle kayıtlı.

Teknolojik Y■ ■ ■ ■ n

Katman	Teknoloji
Dil / Framework	PHP 8.4 · Laravel 12
Veritaban■	PostgreSQL 17
Önbellek / Kuyruk	Redis
Ters vekil	Caddy
Konteynerle■irme	Docker

Çoklu Kiracılık Kararı

N < 1000 kiracıda şema modeli rahat çalışıyor. Ölçek büyürse çözüm tenant_id'ye dönmek değil, kiracılar birden çok veritabanı sunucusuna bölmek — bu ihtimal için tenants.connection alanı imdiden şemada duruyor.

Paylaşımlı Tablo (tenant_id)	Şizle şema (tenant_<uuid>) — SEÇİLEN
Hızlı başlangıç	Biraz daha ağır operasyon
Kalıcı sızma riski	Yapısal güvenlik
Unutulan filtre = veri sızması	Unutulan filtre yapısal olarak imkânsız

Arayüz Mimarisi: Yüzeye Göre Bölünmüş Yığın

“Headless” değil — bilinçli olarak headless değil.

- Vitrin (müşteri): sunucuda render edilen Blade — arama motoru görünürlüğü bir SPA'da güvenilir değil.
- Panel (marka personeli): Inertia + Vue — SEO gerekmiyor, zengin etkileşim önemli.
- Sunucu tarafı render (SSR) bilerek KAPATILDI: SSR süreci tüm markalar için paylaşılan, uzun ömürlü tek bir Node süreci demek.
- Tek kullanıcı sistemde “kullanıcı sözleşmesi” olan şey, çok kiracıda “marka sözleşmesi” oluyor.

Her yüzey kendi doğru aracını kullanıyor — hiçbirisi diğerine paylaşılan bir süreç üzerinden bulaşmıyor.

PostgreSQL İle İlgili Yönetimi

- Merkezde ürün, sipariş veya müşteri verisi hiç yok.
- Her marka için aynı tablo yapısını taşır, birbirinden tamamen bağımsızdır.

```
public schema → yalnızca platform verisi (tenants, domains, plans)
tenant_ schema → ürün, sipariş, müşteri – marka başına TAMAMEN ayrı
```

Asenkron Güç: Redis & Worker Yapısı

- Bugün kuyruktan geçen gerçek işler: sipariş bildirimleri, terk edilmiş ödeme hatırlatması, olay kaydı, KVKK veri işlemleri.
- Worker kodu belleğe alınıyor — deploy sonrasında yeniden başlatılmazsa bayat kodla çalışmaya devam eder (kiracılık kurulumunda gerçekten yaşıyor, artık zorunlu deploy adımı).

İstek → Redis Kuyruğu → Worker (kalıcı süreç) → E-posta / Olay Kaydı / Görsel İşleme

Diyagramdaki kargo/muhasebe entegrasyonları henüz yazılmadılar (Faz 5, planı ama açılmamış) — bugünkü kapsamda yok.

G  venli   deme Katman  

- Kart verisi sunucumuza hi  de miyor.
-   deme formu iyzico'nun kendi sayfas  nda, vitrinimize g  m  l   bir   er  vede (iframe) a     yor.
- PCI DSS kapsam  m  z bu y  zden en dar h  lde.
- 3D Secure ve taksit ak     n   sa  lay  c   y  netiyor.

Dinamik Alan Adı ve TLS

- “Wildcard SSL” değil — on-demand TLS.
- Marka alan adının başladığında Caddy bize sorar, biz veritabanından cevap veririz, sertifika o anda elle müdahale olmadan alınır.
- Haftada en fazla 45 yeni sertifika (Let's Encrypt limiti 50) — bilerek konulmuş bir sınırdır.

Sınır olmasaydı, IP'mize yönlendirilen rastgele bir alan adı bile kotamızı tüketebilirdi.

Sava■ Yaralar■ & Sessiz Hatalar

- Sadece ba■ar■lar■ de■il, geli■tirme sürecinde çözülen sini problemleri de anlat■yoruz.
- Amaç: üretim tecrübesini kan■tlamak.

Saat Dilimi (Timezone) Tuza■

- WooCommerce'te bilinen bir hata: sunucu saat dilimi ile veritaban■ damgas■ uyu■may■nca sipari■ler süresi dolmadan iptal ediliyor.
- Ölçtük: bizde de ayn■ s■n■f hata vard■ — 15 dakikal■k rezervasyon, oturum saat dilimine göre farkl■ anlarda “ölmü■” say■labiliyordu.
- Çözüm: tüm sistemde tavizsiz UTC + oturum saat dilimi sabitlendi, test ile korunuyor.

Çapraz Kirac■ Oturum S■z■nt■s■

■ A markas■nda aç■lan oturum çerezi, B markas■n■n panelini açabiliyordu.

- Oturum yalnızca kullan■c■ id'sini tutuyor; guard onu iste■in kirac■s■n■n ■emas■ndan çözüyor.
- ■ki markada da id=1 olan birer kullan■c■ varsa, A'n■n oturumu B'de de geçerli oluyordu.
- Çözüm: EnsureSessionTenant middleware'i — oturuma giri■te marka kimli■i damgalan■yor, her istekte do■rulan■yor.

Varyant ve SKU Yönetimi

- Renk × Beden gibi kombinasyonlar veritaban■n■ katlanarak büyütebilir.
- Esnek varyant eksenleri (ma■aza seviyesinde tanıml■) ile performans korunuyor.
- Silinen bir SKU'nun kodu sonsuza dek rezerve kal■yor — ayn■ kod bir daha ba■ka bir ■ey ifade etmesin diye.

■ifre S■f■rlama ve Güvenlik Tuzaklar■

■ Laravel'in varsay■lan yap■s■, silindi■i san■lan bir yap■land■rmay■ sessizce geri getirdi.

- Framework config'den bir broker'■ silmek, onu yok etmiyor — varsay■lan altta kal■yor.
- Kalan varsay■lan çapraz ba■l■yd■: mü■teri jetonu, personel ■ifresini s■f■rlayabiliyordu.
- Do■rulama konfigürasyona bakarak de■il, gerçek ge■i■i deneyerek yap■ld■ — aç■k kapat■ld■.

Ortak Önbellek İzolasyonu

- Tek Redis, kiracı bazlı etiketleme (tag) ile izole ediliyor.
- Etiket destekleyen sürücü **art**: file/database sürücülerinde bu koruma çalışmaz.

```
tenant_A:products ↔ tenant_B:products  
(aynı Redis, birbirinden tamamen ayrı anahtar alanı)
```

Yanlış Test Yönlendirmeleri

- Yerelde başarılı geçen bir test, CI'da veya gerçek istekte başarısız olabilir.
- Test istemcisi (postJson/getJson) gerçek tarayıcı davranışını her zaman taklit etmiyor — çerez göndermeyebiliyor, başlık ekleyebiliyor.
- İlke: izole test veritabanı + gerçek HTTP koşullarıyla çapraz doğrulama.

Geli■tirici Deneyimi: Mailpit ve Ngrok

- Mailpit: geli■tirmede gönderilen her e-posta yerel bir kutuda yakalan■r — gerçek mü■teriye asla gitmez.
- Ngrok: d■■ ödeme sa■lay■c■s■n■n webhook'unu yerel ortamda gerçek ko■ullarda test etmek için, yaln■zca ihtiyaç an■nda aç■lan bir tünel.

Proje Anayasas■ (CLAUDE.md)

Amaç h■z de■il, ayn■ hatan■n ikinci kez ya■anmas■n■ engellemek.

- Her madde gerçekten bir kez ya■anm■■, hata vermeden yanl■■ sonuç üreten bir olay■n kayd■.
- Örnek: “Kolon varsay■lan■ modele ula■maz” — bu proje boyunca dört kez ■s■rd■, art■k listede.

Sınırlarımız Zorlamak: Kırma Denemeleri

Failure as a Metric.

- Her kritik özellik, “doğru çalışırken” değil bilerek bozulduğunda test ediliyor.
- Kilidi kaldır, kısıt görev, korumayı sil — test hâlâ geçiyorsa test hiçbir şey kanıtlamıyor demektir.

Ölçekleme Vizyonu

■ PgBouncer kaldırıldı — kendi mimari kararımızla doğrudan çeliyor.

- İma bazı izolasyonda search_path bir oturum ayar; PgBouncer'ın havuzlama modu fiziksel bağlantıyı paylaştırır — bu bir markanın iması'nın başka isteğe sızması demek.
- Gerçek büyüme yolumuz kodda hazır: dikey büyüme → önbellek/indeks → kiracılar birden çok DB sunucusuna bölme (tenants.connection MD5DEN var) → ayrı kuyruk sunucusu → çoklu app sunucusu.
- Kubernetes / ClickHouse gibi araçlar bu sıralamanın sonunda, gerçek bir yük problemi kanıtlandığında değerlendirilecek.

Yol Haritası

Faz	Durum
0-1-2-3-4 — kiracılar, çekirdek mağaza, olgunlaştırma, satılabilirlik, arayüz	Tamamlandı
4.6 — vitrin deneyimi ve ölçüm	Sürüyor
5 — entegrasyonlar (kargo, e-fatura)	Planlı
6 — dağıtım, gözlemlenebilirlik, üretim	Planlı

Sonuç: Neden T■kMarka Kazanacak?

- Do■ru in■a edilmi■ teknoloji, sürdürülebilir ticari ba■ar■ getirir.
- Risk, yap■n■n kendisinden al■n■yor — kod disiplinine b■rak■lm■yor.
- Her iddia ölçülmü■, her karar gerekçeli.

Soru & Cevap

T■kMarka